

Chương 7- Điều khiển truy nhập theo quy tắc

Mandatory Access Control

- Mô hình để biểu diễn **mức bảo mật (security level)** và **quy tắc** là một số cấu trúc toán học trong đại số tuyến tính
 - Tập hợp có thứ tự

7.1) Một số khái niệm

- MAC là điều khiển truy nhập

trong hệ thống

- Các mô hình MAC điển hình
 - Mô hình BLP
 - Mô hình Biba
 - Mô hình dựa trên Lattice

Tập hợp có thứ tự

- Một tập hợp được gọi là tập có thứ tự nếu trên đó có định nghĩa một phép toán quan hệ hai ngôi cho phép xác định phần tử đứng trước và đứng sau trong tập hợp
 - Ví dụ: Tập $\{1, \dots, 10\}$

Tập hợp có thứ tự từng phần

- **Tập hợp có thứ tự từng phần** là tập có thứ tự trong đó

- Ví dụ: Tập $\{1, \dots, 10\}$

7 không chia hết cho 6, 8 không chia hết cho 3

7.2) Mô hình BLP (Bell-LaPadula)

- Mô hình do Bell và LaPadula đề xuất năm 1976, bao gồm:
 - Tập $SL = \{L_i : i = 1 \dots n\}$ là
 - Mỗi một chủ thể và đối tượng được
- Tập SL (Security Level) phải là dựa trên một quan hệ thứ tự được gọi là

- Mức bảo mật L_i được gọi là có **ưu thế** đối với mức bảo mật L_k

A) Quy tắc điều khiển truy nhập

- Quy tắc BLP đơn giản:
 - Một chủ thể S có quyền **đọc** một đối tượng O
- Quy tắc
 - Quy tắc
- Quy tắc *
 - Chủ thể S có quyền **ghi** vào một đối tượng O
- Quy tắc

B) Ví dụ BLP hạn chế trojan horse

Hệ thống có hai mức bảo mật: $SL = \{High, Low\}$

$Low < High$

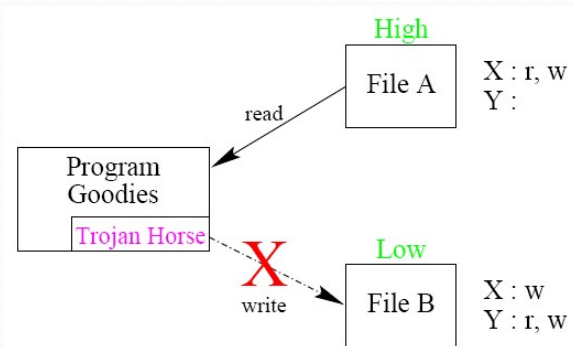
Gán nhãn mức bảo mật cho các thực thể:

$L(X) = High$

$L(Y) = Low$

$L(A) = High$

$L(B) = Low$



Quy tắc * của BLP ngăn chặn Trojan Horse không ghi thông tin từ A vào B mặc dù theo mô hình DAC thì X có quyền ghi vào file B

7.3) Mô hình Biba

- Mô hình Biba do Kenneth J. Biba đề xuất in 1977, gồm có:

- Một tập SL gồm
- SL là
- Các chủ thể và đối tượng

A) Quy tắc điều khiển truy nhập

- Quy tắc Biba đơn giản
 - Một chủ thể S có **quyền đọc** một đối tượng O
 - Quy tắc:
- Quy tắc Biba *
 - Một chủ thể S có **quyền ghi** vào một đối tượng O
 - Quy tắc:

- Tương tự mô hình BLP, mô hình Biba có thể giúp hạn chế việc Trojan horse **sửa đổi trái phép dữ liệu để bảo vệ tính toàn vẹn**

7.4) Mô hình Lattice-based

- Mô hình do Denning đề xuất
 - Hệ thống chia thành nhiều lớp bảo mật tạo thành
- Quy tắc điều khiển truy nhập dựa trên

A) Luồng thông tin (Information flow)

- **Luồng thông tin:** là
- Kí hiệu luồng thông tin từ lớp A đến lớp B:
- Ví dụ
 - Đối tượng O thuộc lớp A, chủ thể S thuộc lớp B
 - Nếu S đọc được O thì

Tính chất của luồng thông tin

- Tính phản xạ:
- Tính bắc cầu:
- Tính phản đối xứng:

Chính sách luồng thông tin

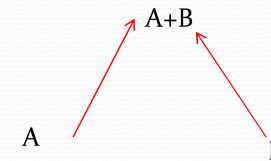
- **Chính sách luồng thông tin:**
- Các truy nhập tuân theo chính sách luồng thông tin là
- Các truy nhập vi phạm chính sách luồng thông tin là
- **Chính sách luồng thông tin chính là**

B) Mô hình biểu diễn chính sách luồng thông tin

- Chính sách luồng thông tin được biểu diễn bằng một mô hình gồm **bộ ba** $(SC, \rightarrow, +)$ trong đó:
 - SC là
 - $\rightarrow$ là trên SC , thể hiện
 - $+$ là phép toán kết hợp

• Giải thích phép toán $+$

- Cho 2 lớp bảo mật A và B , $A + B$ là một lớp bảo mật có thể tiếp nhận thông tin từ cả A và B
- $A + B$ tạo ra



Cấu trúc tập hợp Lattice

- Mô hình **bộ ba** $(SC, \rightarrow, +)$ cần thỏa mãn các điều kiện sau
 - tập SC là hữu hạn
 - Phép toán $\rightarrow$ là một quan hệ có thứ tự từng phần trên tập SC
 - SC có **một cận dưới thấp nhất** M sao cho $M \rightarrow A$ với mọi A thuộc SC
 - Với mọi A và B thuộc SC , ta luôn tìm được C thuộc SC sao cho $A + B = C$

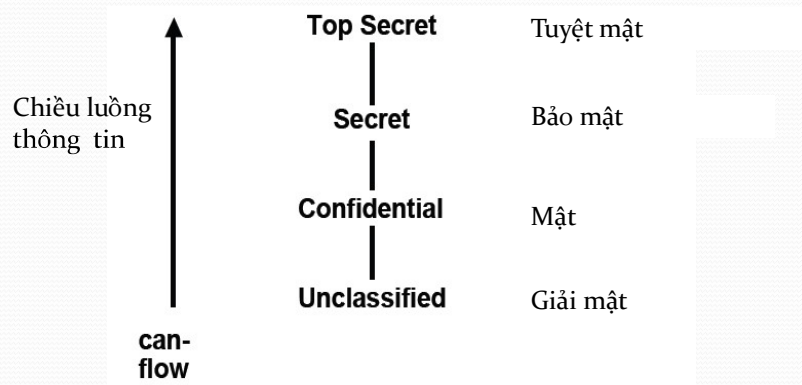
• Khi đó mô hình $(SC, \rightarrow, +)$

- Về cơ bản, Lattice là 1 tập có thứ tự từng phần còn tập có thứ tự từng phần chưa chắc đã là 1 Lattice
- Hai phần tử bất kỳ của 1 Lattice luôn có duy nhất

D) Các dạng cấu trúc lattice

• *) Cấu trúc Lattice đơn nhánh

Các lớp bảo mật



Tiếp

• *) Cấu trúc Lattice dạng mắt lưới

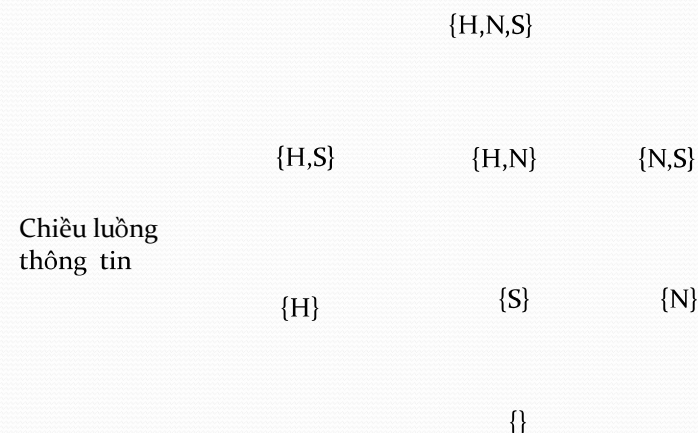
Các lớp bảo mật

- Dùng trong hệ thống có nhiều **bộ phận**. Ví dụ: 1 công ty có:
 - Bộ phận Hardware: H
 - Bộ phận Networking: N
 - Bộ phận Software: S
- Từ các bộ phận, lập ra các lớp bảo mật là các tập hợp sau
 - {}, {H}, {S}, {N}, {H,S}, {H,N}, {N,S}, {H,S,N}

- Luồng thông tin hợp lệ đi từ tập con $\rightarrow$ tập cha. Ví dụ:

- Không có luồng thông tin giữa 2 tập hợp không phải cha-con. Ví dụ :

Ví dụ



Cấu trúc: chia nhiều nhánh, xuất phát từ mức thấp nhất và dịch chuyển đến mức cao nhất qua các lớp trung gian

E) Một số tính chất của Lattice

- Tích của hai lattice là một lattice
- Một tập con bất kỳ của lattice không nhất thiết là một lattice nhưng
- Cho một tập có thứ tự từng phần, ta luôn có thể bổ sung thêm các phần tử và luồng thông tin

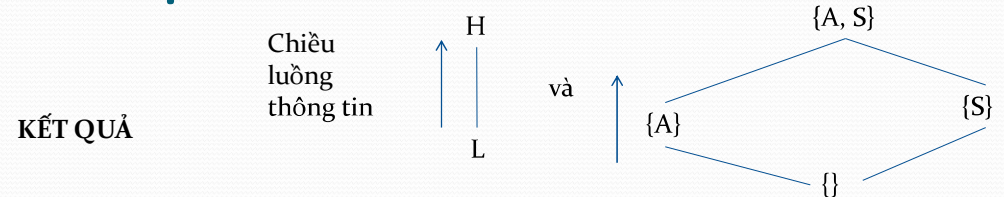
F) Kết hợp Lattice

- Hai lattice nhân với nhau luôn tạo ra một lattice
- Lattice thu được sẽ biểu diễn chính sách luồng thông tin kết hợp

Quy tắc kết hợp

- Sử dụng tích Descartes (Đề các) trên tập hợp có thứ tự
- Giả thiết
 - Cho lattice L_p gồm các lớp $P = \{p_1, p_2, \dots, p_n\}$
 - Cho lattice L_q gồm các lớp $Q = \{q_1, q_2, \dots, q_m\}$
- Lattice kết hợp $L_R = L_p \times L_q$ có:
 - Tập lớp bảo mật
 - Luồng thông tin: $(p_i, q_j) \rightarrow (p_k, q_l) \Leftrightarrow$

Ví dụ



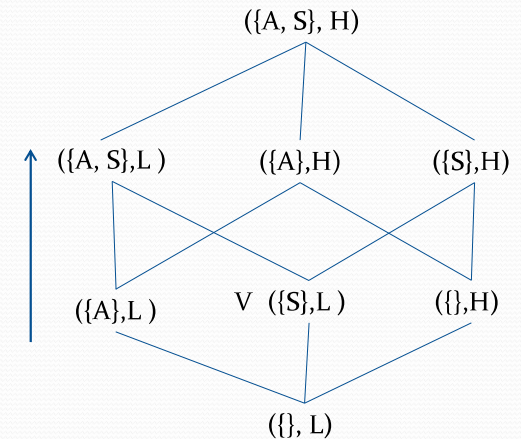
- Một lattice đơn nhánh gồm hai mức H và L
- Một lattice mắt lưới tạo thành từ tập ngăn

G) Gán lớp bảo mật cho chủ thể và đối tượng

- Để điều khiển truy nhập, cần gán lớp bảo mật cho các chủ thể và các đối tượng
- Theo quy tắc, thông tin chỉ có thể dịch chuyển theo chiều của luồng thông tin
 - $A \rightarrow B$: chủ thể thuộc lớp A có thể
 - $A \rightarrow C$: chủ thể lớp C có thể
 - Chủ thể thuộc lớp A có thể vừa

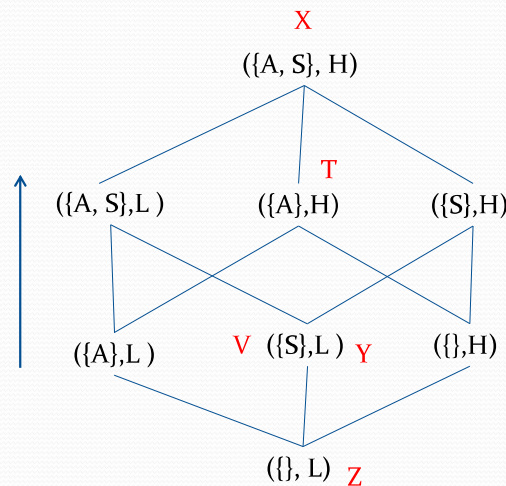
Ví dụ về cách gán nhãn bảo mật cho đối tượng

- Tài liệu X là báo cáo tổng hợp từ bộ phận A và bộ phận S, có mức bảo mật cao. Hãy lớp bảo mật cho X
- Tài liệu Y là đơn hàng của bộ phận S, mức bảo mật thấp. Chọn lớp bảo mật cho Y
- Tài liệu Z là phổ biến cho toàn đơn vị có thể đọc. Hãy chọn lớp cho Z
- Chủ thể T có mức ưu thế cao và làm việc tại bộ phận A.
- Chủ thể V có mức ưu thế thấp và làm việc tại bộ phận S



Tiếp

- Chỉ ra các quyền của T đối với X, Y, Z
- Chỉ ra các quyền của V đối với X, Y, Z



Kết hợp DAC và MAC

- Trên thực tế, ta có thể MAC (theo luồng thông tin) sẽ được kết hợp với DAC (theo ma trận truy nhập)
- MAC sẽ đóng vai trò
 - Bước 1: Điều khiển theo ma trận truy nhập. Nếu đúng phân quyền thì chuyển sang bước 2
 - Bước 2: Áp dụng quy tắc luồng thông tin. Nếu truy nhập hợp lệ thì được phép, ngược lại sẽ bị chặn.

7.5) So sánh các mô hình BLP, Biba và Lattice-based (đọc thêm)

A) Giống nhau

- Cùng dựa trên phân cấp theo cấp độ bảo mật hoặc lớp bảo mật
- Mỗi chủ thể và đối tượng được gán vào một lớp bảo mật
- Điều khiển truy nhập phải tuân theo các quy tắc
- Trong cả 3 mô hình đều có luồng thông tin

B) Khác nhau BLP và Biba

• Khác nhau

- Lớp bảo mật của BLP là mức độ bí mật, của Biba là mức độ toàn vẹn dữ liệu
- Các quy tắc của BLP và Biba là ngược chiều nhau
 - BLP: no read up – no write down
 - Biba: no read down- no write up
- Mục đích của 2 mô hình là khác nhau
 - BLP nhằm ngăn chặn rò rỉ thông tin và giữ tính bí mật
 - Biba nhằm ngăn chặn sửa đổi thông tin trái phép và giữ tính toàn vẹn

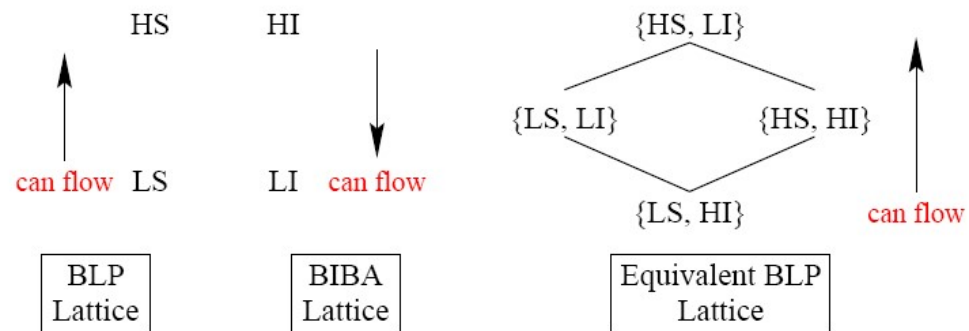
Đánh giá

- Mô hình BLP và Biba bổ sung cho nhau nhưng quy tắc ngược chiều nhau nên khó áp dụng cùng 1 lúc
- Ưu điểm của mô hình Lattice
 - Biểu diễn quy tắc luồng thông tin bằng Lattice và có khả năng kết hợp các chính sách luồng thông tin với nhau
 - Tổng quát hơn BLP và Biba → có thể dùng để kết hợp BLP và Biba

Kết hợp Mô hình BLP và Biba bằng Lattice

- Điều kiện để kết hợp
 - Có thể biểu diễn mô hình BLP và Biba thành 2 lattice
 - Biến đổi 1 trong 2 lattice sao cho luồng thông tin đi cùng chiều
 - Kết hợp 2 lattice theo quy tắc chung

Minh họa kết hợp BLP và Biba



Kết hợp BLP và Biba (hai lattice đơn nhánh)

- Quy tắc Điều khiển truy nhập của mô hình thu được sẽ theo **chính sách luồng thông tin của lattice kết hợp**